

サプライチェーンと情報セキュリティ: 調査課題

学籍番号: v25y0009

氏名: Davaakhuu Undarmaa

- サプライチェーンの事例を調べ、事例を 1 つ決め、調査項目に従いその事例を整理しなさい。

1. 調査レポート構成

(事例は、2021 年に Kaseya 社のリモート管理ソフト「VSA」の脆弱性を悪用し、ランサムウェアが拡散したサプライチェーン攻撃である。攻撃者は Managed Service Provider (MSP) を経由して多数の顧客企業に被害を及ぼした。本事例は、委託先サービスやソフトウェア更新への信頼が悪用された点に特徴があり、外部委託リスクおよびソフトウェアサプライチェーンリスクに分類される。) Managed Service Provider (MSP) : 会社のコンピューターやネットワークを、外部からまとめて管理してくれる会社のことです。

REvil による攻撃では、Kaseya VSA サーバが SQL インジェクション攻撃に対して脆弱であり、脅威アクターがそれを悪用してリモートから侵害できる状態にあったことが判明しましたこの脆弱性には CVE-2021-30116 が割り当てられています。

(1) 攻撃(または脆弱性)経路の整理

• 侵害の起点

本事例における侵害の起点は、Kaseya 社のリモート管理ソフトウェア「VSA」サーバである。VSA に存在していた SQL インジェクションの脆弱性 (CVE-2021-30116) が悪用され、攻撃が開始された。

• 侵入経路

攻撃者 (REvil) は、VSA サーバの Web インタフェースに対して SQL インジェクション攻撃を行い、不正なコマンドを実行することで リモートからサーバへの侵入に成功した。その後、VSA の管理機能を悪用して、接続されているクライアント環境へとランサムウェアを拡散させた。

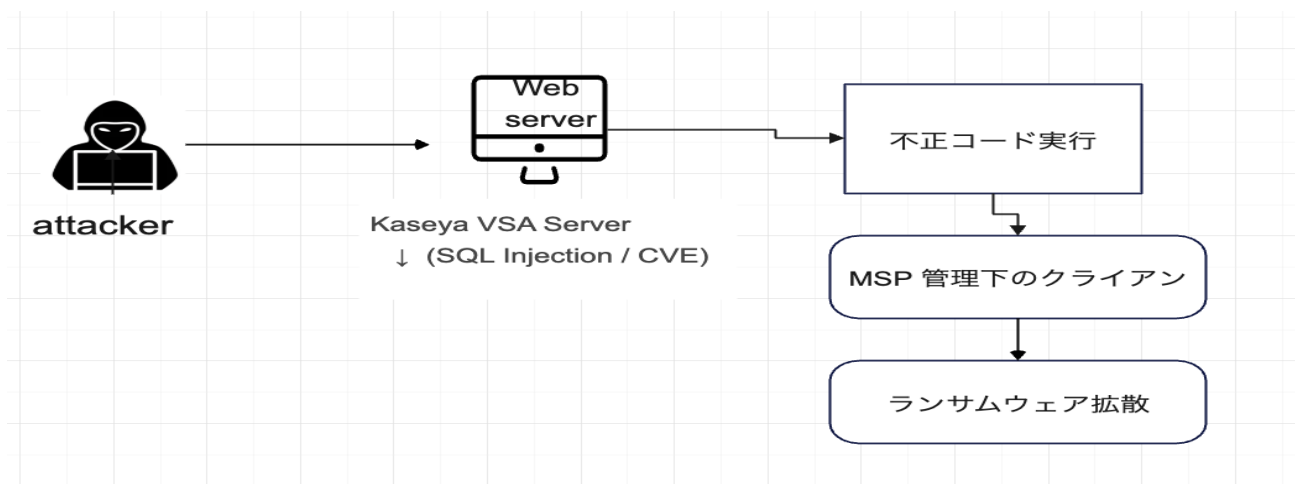
• 関係する外部委託・OSS・サービス

本攻撃には、Managed Service Provider (MSP) 向けの管理サービスである Kaseya VSA が関係している。VSA は多数の企業システムを一元管理するサービスであり、その特性が攻撃の影響範囲を拡大させる要因となった。

• 信頼の連鎖のどこが悪用されたか

本事例では、MSP と顧客企業の間が存在する信頼関係が悪用された。

クライアントは、MSP を通じて配信される更新や管理操作を信頼していたため、攻撃者が VSA を通じて配布したランサムウェアが正規の更新であるかのように実行されてしまった。



図：攻撃の flow

(3) 影響範囲の分析

■ 技術的影響

Kaseya VSA の脆弱性が悪用されたことにより、VSA を通じて管理されていた多数のクライアント端末にランサムウェアが配布された。Kaseya VSA サーバに存在した脆弱性（特に CVE-2021-30116 など）を悪用した結果、攻撃者はリモートから VSA サーバに侵入し、管理下にある多数の MSP クライアントに対して不正コードを配布した。これにより対象システム上のファイルやデータがランサムウェアによって暗号化され、サーバ停止、情報破損、復旧処理の必要性といった技術的被害が発生した。

- 不正アクセスによるシステム制御の奪取
- ファイル暗号化およびサービス停止
- 多数のクライアント端末へのランサムウェア配布

■ ビジネス／社会的影響

本攻撃により、多くの企業で業務が停止し、システム復旧やインシデント対応に多大なコストと時間が必要となった。本インシデントは単なる技術問題にとどまらず、複数の企業において業務停止、重大な損害発生、復旧コストの増加を引き起こした。

さらに MSP（マネージドサービスプロバイダー）経由で広範囲に影響が及んだことで、サプライチェーン全体の信頼性低下という社会的影響も発生した。

顧客企業や取引先に対する影響、被害額の大きさ、ブランド価値の低下などが社会的な波及効果として現れている。

- 業務停止による経済的損失
- サプライチェーン全体の信頼低下
- 影響を受けた企業の社会的信用への打撃

■ 利用者への影響

利用者は、業務システムや提供サービスを一時的に利用できなくなり、重要な業務データへのアクセスが制限された。これにより、業務の遅延やサービス停止が発生し、利用者に不安や混乱を与える結果となった。サービスの利用停止、データアクセス不能、利用者の業務遅延・不安感。

(4) サプライチェーン上の課題

● 単独組織では防げなかった理由

Kaseya VSA は、MSP（マネージドサービスプロバイダー）を通じて多数の企業システムを一元管理する構造を持っていた。

そのため、VSA サーバ自体が侵害されると、その管理下にあった複数の組織が同時に攻撃の影響を受ける結果となった。

この事例は、個々の企業が十分なセキュリティ対策を講じていたとしても、外部サービス事業者が侵害された場合には、単独組織だけでは攻撃を防ぐことが困難であることを示している。

● 依存関係の可視化不足

MSP と利用企業との間で、どのシステムがどのような権限を持って接続されているのかといった依存関係が十分に可視化されていなかった。

Kaseya VSA のアップデート配布やスクリプト実行機能は、高い信頼を前提として自動化されており、その仕組みが結果として攻撃者に悪用される「信頼の連鎖（トラストチェーン）」となった。

このことから、依存関係の把握と可視化の不足が、被害拡大の一因となったことが分かる。

● 技術・運用・契約面の課題

技術面では、VSA サーバに管理機能が集中していたことにより、単一障害点（Single Point of Failure）が存在していた。

運用面では、脆弱性情報の共有やインシデント発生時の対応手順が、MSP と利用企業の間で十分に整理・共有されていなかった。

さらに契約面においては、セキュリティインシデント発生時の責任範囲や役割分担が明確でないケースも多く、対応の遅れや混乱を招いた。

(5)再発防止策の提案

- 技術対策（SBOM、署名、CI/CD 保護 等）

Kaseya VSA のようにソフトウェア更新機能が攻撃に悪用された事例を踏まえ、ソフトウェアの構成要素を明確に管理する SBOM（Software Bill of Materials）の導入が有効である。これにより、どのコンポーネントに脆弱性が存在するかを迅速に特定でき、被害の拡大を防止できる。また、アップデートやスクリプト配布に対する デジタル署名の検証を必須とすることで、不正なコード配布を防ぐことが可能となる。

さらに、CI/CD パイプラインのアクセス制御や監視を強化することで、開発・配布段階での侵害リスクを低減できる。

有効性：信頼される更新経路のみを許可することで、攻撃者が正規の更新機能を悪用するリスクを低減できる。

- 組織・運用対策（委託管理、監査 等）

MSP や外部ベンダーに対して、セキュリティ要件を明確に定めた委託管理を行うことが重要である。定期的なセキュリティ監査や脆弱性評価を実施し、委託先のセキュリティ成熟度を継続的に確認する必要がある。また、インシデント発生時の連絡体制や対応フローを事前に定義し、関係組織間で共有しておくことが求められる。

有効性：委託先を含めた統一的な運用ルールにより、サプライチェーン全体のセキュリティ水準を底上げできる。

- レジリエンス（代替策、BCP）

Kaseya VSA 事件では、一つの管理基盤が停止することで広範囲に影響が及んだ。この教訓から、管理サーバの冗長化や代替運用手段の確保など、レジリエンス向上策 が重要である。加えて、ランサムウェア被害を想定したバックアップ体制や BCP（事業継続計画）を整備し、定期的な訓練を行うことで、被害発生後も迅速な業務復旧が可能となる。

(6)事例から学べる点

本事例から、サプライチェーン攻撃は単一の組織の問題にとどまらず、信頼している委託先や利用しているツール、さらには顧客を含む広範囲に影響を及ぼすことが分かる。特に MSP のような中間事業者が侵害された場合、多数の組織に被害が連鎖的に拡大する可能性が高い。また、正規のアップデートや管理機能に対する信頼が攻撃に悪用されるケースもあるため、単独組織による対策には限界がある。したがって、サプライチェーン全体でリスクを捉え、依存関係の可視化、セキュリティ管理の強化に加え、BCP やレジリエンスといった事前の備えを整備することが重要である。

(2) 参考文献

1. https://www.ironnet.com/blog/ransomware-attack-update-revil-is-reveling-across-msp-supply-chain?utm_source=chatgpt.com
2. <https://www.varonis.com/blog/revil-msp-supply-chain-attack>
3. CISA (Cybersecurity and Infrastructure Security Agency)
4. Kaseya (Kaseya VSA Incident Updates) <https://www.kaseya.com/potential-attack-on-kaseya-vsa/>